



Figure 1: An MITM attack

OSI Layer	MITM Attack Type
Application	Cookies Injection, MITB
Presentation	SSL Hijack
Transport	IP Spoofing
Data Link	ARP Poisoning ICMP MITM

Figure 2: The MITM attacks that can take place at different OSI layers

ID and password information from it, which can be used by an attacker to impersonate the victim and create more damage. We again wish to emphasise that MITM is a stealth type of attack whereby the victims cannot detect the presence of hacker on the network, and hence this attack should be taken very seriously. The good news is that there are a few ways to stop or at least mitigate the impact of this attack, which you will soon learn about. Now let's take a look at various MITM attacks that take place at different networking layers.

ARP Poisoning: ARP does MAC address-to-IP address translation. In a normal situation, when a TCP/IP protocol stack running on one computer wants to send a packet to a destination IP address, it first looks into its local cache for a mapping of the IP with a MAC address. If the entry can't be found, it starts an ARP broadcast, asking for a MAC address for the given IP address. The machine that owns that IP address responds to the ARP query with its own MAC address. The source then uses it to create the Ethernet frame, and starts transmission to that address, and also stores the IP-to-MAC entry in its local cache, to speed up future communication to the same IP. ARP is a stateless protocol, and the cache doesn't have its own security mechanism, which yields a serious vulnerability. The MITM being based on packet spoofing and forging, the attacker sends spoofed ARP packets on the LAN to associate the attacker's own machine's MAC address with the IP address of the target host. This forged packet can be as simple as an ICMP packet typically used to ping a host. Traffic meant for the target now reaches the attacker's

machine, due to the cached IP-to-MAC entries. The attacker can repeat this on another machine, to view communication between both the targets—thus making it a LAN-specific MITM attack. Once control is achieved, the attacker simply collects packets from the sender, and forwards them to the receiver, while recording the packet stream inbetween. Since there is no data lost, both victims have no clue; the attacker steals data in hiding. ARP poisoning is widely used in internal attacks, i.e., by attackers on the same LAN.

DNS MITM: This method is rarely used, but can create a serious security breach. An attacker first sniffs network traffic specifically for DNS queries on port 53. Gathered information is analysed to identify all DNS servers on the network. The attack uses ARP spoofing to fool the querying machine into sending DNS requests to the attacker's computer, rather than the real DNS server. Every DNS query contains a unique identification number to be able to map it to the response received. For the MITM, the query response packet needs this number, but with a bogus query answer. In real life, a DNS MITM is tough to execute, and is also time-consuming; however, it leads to a great deal of network insecurity. Please refer to Figure 3, which explains this attack in more detail. What could be achieved is up to the attacker's imagination. As an example, the attackers can divert all requests to a Web server to their own IP address(es), create a phishing website, and steal credentials. If this attack is planted externally, the damage can actually be beyond imagination. In another form of DNS MITM attack, the attackers stress the DNS server by sending a large number of queries, and meanwhile intercept its traffic, to send bogus responses to DNS queries.

DHCP MITM: Similar to the DNS attack, here, the DHCP server's queries and responses are intercepted. This helps the attacker gain a complete picture of the network, such as hostnames, MAC addresses, IP addresses, DNS servers, etc. This information is further used to plant advanced attacks to steal information. Also, like the DNS attack, attackers can use a denial-of-service attack on a real DHCP server to keep it busy, while they spoof responses to DHCP queries. A DHCP MITM just acts as a catalyst in the data-stealing process. However, the impact can be further increased either by expiring the IP lease on all hosts, thus causing a DHCP broadcast storm on the network, or by assigning the same IP to all hosts, to render the network practically non-functional.

MITM attacks from the application perspective

Cookie hijacking: As we know, a cookie is a small piece of text stored by a browser on the user's machine and stores information related to the website that created it, usually to 'remember' users' online membership details or profile settings, etc. Stored cookies can be accessed by the browser as well as other applications. By writing cookie-stealing scripts or programs, part or all of the cookie content can be captured, interpreted and presented to the Web server, in order to impersonate the user, who now becomes a victim in this scenario. There are three ways to capture cookie details—directly access it on the computer, hijack the browser session, or sniff Web requests and responses transmitted over